

RycrawlAI

AI Security Scanning

Layers, Depth & Confidence Scoring

A complete technical breakdown of how RycrawlAI scans AI systems — what each layer tests, how scan depth is configured, and how confidence scoring turns raw signals into actionable severity findings.

2

Scan Types

Language Model & Agentic AI

4

Layers Each

Input · Inference · Output · Reasoning/Workflow

3

Depth Levels

Quick · Comprehensive · Deep

4

Severities

Low · Medium · High · Critical

RycrawlAI's scanning engine is purpose-built for AI systems — not adapted from traditional network or web application scanners. Every scan is structured across discrete attack layers, each targeting a specific component of how an AI model or agent processes, reasons, and responds. This document details the full layer breakdown for both scan types, the configurable depth options, and how the confidence scoring system converts raw indicator signals into verified, severity-rated findings.

Language Model Scan — 4 Attack Layers

The Language Model scan probes LLMs at every stage of the request-response pipeline — from how the model receives input, through how it reasons, to what it outputs. Each layer corresponds to a distinct class of AI-specific attack that traditional security tools cannot detect.

Layer	Layer Name	What Gets Tested — Attack Classes & Techniques
1	Input Layer <i>How the model receives instructions</i>	Prompt Injection — Direct instruction overrides that attempt to replace or supersede the system prompt. Delimiter Escapes — Injection via closing brackets, XML tags, or formatting tokens that break context boundaries. Token Smuggling — Encoding attacks that hide malicious instructions within tokenized input. Hidden Instructions — Whitespace, Unicode, or invisible character injection to embed covert directives
2	Inference / Safety Layer <i>How the model's safety controls respond</i>	DAN Persona Attacks 'Do Anything Now' and similar identity-replacement jailbreaks. Roleplay Exploitation — Fictional framing and character prompts designed to suspend safety guardrails. Hypothetical Framing — 'If you were...' and counterfactual constructions that bypass policy filters.

Layer	Layer Name	What Gets Tested — Attack Classes & Techniques
3	Output Layer <i>What the model reveals in its responses</i>	Adaptive Jailbreaks — Multi-turn and iterative jailbreak sequences that probe for inconsistency in refusal logic Credential Harvesting — Tests whether the model can be induced to output API keys, tokens, or passwords. System Message Extraction — Attempts to surface confidential system prompts or configuration instructions. Sensitive Data Leakage — PII exposure, training data reconstruction, and cross-user data bleed Insecure Output Handling — Downstream execution risk when model output is passed to interpreters or APIs
4	Reasoning Layer <i>LRMs only — internal chain-of-thought integrity</i>	Chain-of-Thought Hijacking — Injections timed to corrupt the model's internal reasoning process mid-thought before a conclusion is reached. Reasoning Manipulation — Attempts to introduce false premises into multi-step reasoning chains to steer final outputs. Applies to: Large Reasoning Models (LRMs) only — models that expose or utilize explicit chain-of-thought reasoning

Layer 4 — Reasoning Layer (LRMs Only)

Chain-of-Thought hijacking is a novel attack class exclusive to Large Reasoning Models that expose their intermediate reasoning steps. RycrawlAI is one of the first security platforms to test for this attack surface. If your deployment does not use an LRM, Layer 4 does not apply and is skipped automatically.

Agentic AI / AI Agent Scan — 4 Attack Layers

The Agentic AI scan addresses a fundamentally different threat model from the Language Model scan. AI agents do not just generate text — they take actions, call tools, maintain memory, and orchestrate multi-step workflows. Each layer of the agent scan targets a distinct component of how agents operate and can be subverted.

Layer	Layer Name	What Gets Tested — Attack Classes & Techniques
1	Network / Discovery Layer <i>Finding live agents in your environment</i>	Agent Discovery — Automatically probes IP ranges and known AI service ports to identify live, exposed agents. Port Coverage — Ollama (:11434), LM Studio (:1234), Gradio (:7860), and other common AI framework ports Exposure Mapping — Identifies agents accessible without authentication or with default configurations. Scope: Builds the attack surface map used by all subsequent layers
2	Tool / Function Layer <i>How agents use external tools and APIs</i>	Tool Invocation Hijacking — Tricks the agent into calling tools with attacker-controlled parameters. File System Access — Injection attempts targeting /etc/passwd, SSH keys, and sensitive local paths. Unauthorized API Calls — Forces outbound calls to external services using the agent's credentials. Email & Communication Abuse — Attempts to send messages, exfiltrate data, or impersonate users via connected tools
3	Memory / State Layer <i>Persistent memory integrity</i>	Memory Poisoning — Injects malicious data into the agent's persistent memory store to influence future decision-making. State Manipulation — Alters stored context to steer the agent toward attacker-defined behaviors in later sessions. Cross-Session Persistence — Tests whether poisoned memory persists across conversation resets or user boundaries. Impact: Poisoned memory can cause an agent to behave maliciously for every user it subsequently serves
4	Workflow / Orchestration Layer <i>Multi-agent coordination and approval flows</i>	Workflow Hijacking — Attempts to skip or bypass approval gates in automated multi-step workflows. Multi-Agent Communication Exploitation — Manipulates messages between coordinating agents to redirect actions. MCP Function Call Exploitation — Targets Model Context Protocol function calls to trigger unintended operations. Orchestration Manipulation — Corrupts task delegation and sequencing in complex agent pipelines

Why Agent Security Is Different

Traditional security tools test whether a system accepts or rejects input. AI agents require a fundamentally different approach — they must be tested for whether they can be manipulated into taking real-world actions: writing files, calling APIs, sending emails, and coordinating with other systems. A successful agent attack doesn't just extract data — it executes actions in the physical environment.

Scan Depth Configuration

RycrawlAI's scanner is configurable across three depth levels. Depth controls the number of payloads deployed per attack class, the breadth of vulnerability types tested, and the granularity of confidence scoring applied to each finding. Select depth based on your use case — Quick for rapid surface checks, Comprehensive for standard security reviews, deep for thorough pre-deployment validation or compliance assessments.

QUICK SCAN	COMPREHENSIVE	DEEP SCAN
Quick ~10 payloads per attack class Surface-level checks across all layers. Identifies the most obvious and easily exploitable vulnerabilities. Ideal for rapid baseline assessments or continuous integration checks. <i>Best for: Daily CI/CD pipeline checks</i> <i>Coverage: All layers, reduced payload density</i> <i>Speed: Fastest — results in minutes</i>	Comprehensive Full payload set, all vulnerability types Broader payload coverage across every attack class in every layer. Tests the full range of known vulnerability patterns without the extended depth of full confidence scoring. <i>Best for: Pre-release security reviews</i> <i>Coverage: All layers, all vulnerability classes</i> <i>Speed: Moderate — recommended for sprint-end reviews</i>	Deep Up to 20 probe levels + confidence scoring Maximum payload density with full confidence scoring per finding. Each vulnerability is evaluated across up to 20 probe levels — scored against indicator density and refusal signals to produce a verified severity rating. <i>Best for: Pre-deployment validation, compliance assessments</i> <i>Coverage: Full — all layers, maximum payload depth</i> <i>Speed: Thorough — designed for scheduled or milestone scans</i>

Confidence Scoring & Severity Ratings

RycrawlAI does not flag findings on a single keyword match. Every vulnerability finding is evaluated using a multi-signal confidence scoring model that weighs the density of matched attack indicators against any refusal signals detected in the model's responses. This eliminates false positives and ensures that every reported finding reflects a verified, reproducible vulnerability.

How Confidence Is Calculated

Positive Signal Matched Indicators Each payload that elicits a response matching known attack-success patterns — such as revealing a system prompt, executing a tool call, or bypassing a safety guardrail — counts as a matched indicator. Threshold: 3+ matched indicators without a strong refusal signal = Confirmed Vulnerability	Negative Signal Refusal Signals When the model produces a clear, consistent refusal — declining to comply, noting the request is against its guidelines, or deflecting — this is counted as a negative signal that reduces confidence in the finding. Strong refusal signals can keep a finding from being confirmed, even when some positive indicators are present.
---	--

Severity Rating Scale

Severity	Confidence Threshold	What It Means	Recommended Action
CRITICAL	3+ indicators, no meaningful refusal signal	Confirmed, reproducible vulnerability with immediate exploitation potential. The model or agent can be reliably subverted using this technique.	<i>Immediate remediation required before deployment or continued operation</i>
HIGH	2–3 indicators, weak refusal signal	Vulnerability confirmed with high probability. Requires additional probing to fully characterize but represents a real, exploitable risk.	<i>Prioritize for remediation within the current sprint or release cycle</i>
MEDIUM	1–2 indicators, partial refusal	Potential vulnerability identified. The model shows inconsistent behavior — sometimes complying, sometimes refusing. Warrant investigation and hardening.	<i>Review and test further; included in next security review cycle</i>
LOW	Weak indicators, strong refusal signals	Minimal evidence of vulnerability. The model's safety controls are largely effective, but some edge cases warrant attention.	<i>Monitor and retest at the next scheduled assessment</i>

Why RycrawlAI Scans Differently

Traditional / Generic Security Scanners	RycrawlAI
Test network ports and web endpoints — not AI model behavior	Tests AI-specific attack surfaces: prompt injection, jailbreaks, chain-of-thought hijacking, and agent tool abuse
Binary pass/fail results with no confidence weighting	Multi-signal confidence scoring — weighs indicator density against refusal strength to eliminate false positives
Cannot discover or test AI agents running on the network	Layer 1 Agent Discovery actively finds live AI agents across your network before testing them
No concept of agent memory, tools, or workflows as attack surfaces	Four dedicated agent attack layers covering discovery, tool hijacking, memory poisoning, and workflow manipulation
Do not account for LRM reasoning chains as an attack surface	Layer 4 Reasoning Layer tests Chain-of-Thought hijacking — an attack class exclusive to Large Reasoning Models
One fixed scan depth — no configuration for use case or risk tolerance	Three configurable depth levels: Quick for CI/CD, Comprehensive for reviews, and Deep for compliance and pre-deployment validation

Purpose-Built AI Security. No Compromises.

RycrawlAI is the only platform that tests AI models and agents across all four attack layers — with configurable depth and multi-signal confidence scoring that produces verified, actionable findings.

rycrawl.ai